Cybersecurity Fundamentals

Principles, risk, controls, and incident response

Personal study and revision reference

Contents

Security Fundamentals 3
Threats, Vulnerabilities, and Risk 4
Risk Management 6
Security Controls 7
Incident Response 8

Security Fundamentals

Purpose of cybersecurity

Cybersecurity protects systems, networks, people, and information from unauthorized access, disruption, alteration, or destruction. A security decision should preserve business services while reducing the likelihood or impact of harm.

Why it matters

An organization depends on trustworthy information and available services. A compromised account, altered record, or unavailable system can affect customers, operations, safety, and legal obligations.

The CIA triad

Property	Meaning	Example
Confidentiality	Information is seen only by authorized parties.	Restrict payroll records to approved roles.
Integrity	Information remains accurate and changes are authorized.	Log and validate changes to a payment record.
Availability	Systems and information are usable when needed.	Maintain tested backups and redundant service capacity.

Controls often support more than one property. Encryption can protect confidentiality, while hashes and signed records can help detect unauthorized changes. Backups support availability, but do not alone ensure a service can be restored quickly.

Practical example

For an online appointment service, access control limits who can view patient data (confidentiality), audit trails record updates (integrity), and resilient hosting with recovery procedures helps keep booking available.

Common mistakes

- Treating the CIA properties as interchangeable. A control can improve one property while leaving another weak.
- Assuming encryption alone makes data secure. Key handling, access, endpoints, and recovery still matter.
- Equating a successful backup job with a tested recovery capability.

Identity and access

Authentication establishes which identity is requesting access. Authorization determines what that identity may do. Accounting or auditing records relevant actions.

Term	Question answered	Example
Authentication	Who are you?	Password plus a security key.
Authorization	What may you access or change?	A help-desk role can reset accounts but cannot export payroll.

Term	Question answered	Example
Auditing	What happened, and by whom?	A record of a privileged configuration change.

Use least privilege: grant only the access needed for a defined task and review it when roles change. Multi-factor authentication combines different factor types, such as something known and something possessed; two passwords are still one factor type.

Security operations and monitoring

Security monitoring reviews events from endpoints, identity systems, networks, and applications to find activity that needs investigation. Logs provide records of events; a SIEM collects and correlates events to support searches, alerts, and investigations.

An alert is a signal to examine, not proof of an incident. Analysts validate context, preserve evidence, determine scope, and follow the organization's escalation process. Time synchronization, useful log fields, retention, and access controls affect whether records can support an investigation.

Practical example

A SIEM rule may flag repeated failed logins followed by a successful login from an unusual source. The analyst checks the account history, source details, endpoint activity, and user context before deciding whether to contain or escalate.

Common mistakes

- Treating every alert as a confirmed compromise.
- Ignoring false negatives, missing data sources, or incorrect time settings.
- Collecting logs without limiting access or retention to an approved policy.

Revision points

- Start with confidentiality, integrity, and availability; identify which property is at risk.
- Separate identity verification from permission decisions.
- A log is evidence of an event; a SIEM helps organize and correlate it; an alert still requires investigation.
- Apply least privilege, record important activity, and test recovery arrangements.

Threats, Vulnerabilities, and Risk

Key terms

Term	Meaning	Example
Asset	Something valuable that needs protection.	Customer data, a service, or an employee account.
Threat	A circumstance or actor that could cause harm.	A phishing campaign targeting staff.

Term	Meaning	Example
Vulnerability	A weakness that can be exploited or otherwise cause failure.	An unpatched internet-facing application.
Exploit	A method or code that takes advantage of a vulnerability.	A crafted request that triggers an application flaw.
Risk	The potential for loss, commonly assessed through likelihood and impact.	A reachable flaw could expose sensitive records.

Threat, vulnerability, and risk are related but not synonyms. A vulnerability may exist without a likely threat path; risk depends on context, exposure, impact, and existing safeguards.

Assessing a scenario

Use a repeatable sequence:

1. Identify the asset and the harm that matters.
2. Identify relevant threats and weaknesses.
3. Estimate likelihood and impact using the organization's method.
4. Consider existing controls and residual risk.
5. Record an owner, decision, and review date for treatment.

Example

An internet-facing service stores customer details. The service has a known unpatched weakness. The asset is customer information; the threat could exploit the exposed service; the weakness is the missing patch; potential impact includes unauthorized disclosure and service disruption. The team should validate exposure and business impact, apply the approved remediation, and verify the fix.

Common misconceptions

- A threat is not the same thing as a vulnerability: one can exploit the other.
- Risk is not a fixed property of a vulnerability; exposure and business impact change it.
- A high-severity score is an input to prioritization, not a complete business risk decision.
- "No known exploitation" does not prove that a weakness is harmless.

Revision points

- Trace the relationship: asset -> threat path -> weakness -> possible impact -> risk.
- Include current safeguards when estimating remaining risk.
- Record assumptions and revisit decisions as exposure or threat conditions change.

Risk Management

Managing security risk

Risk management is the continuing process of identifying, assessing, treating, and reviewing risks in the context of organizational priorities. It helps teams decide where to spend limited time and resources and who is accountable for a decision.

Common treatment choices

Choice	Meaning	Example
Mitigate	Reduce likelihood or impact with safeguards.	Patch a service and restrict its network exposure.
Avoid	Stop the activity that creates the risk.	Retire an unsupported service.
Transfer/share	Allocate some financial or operational impact to another party.	Use an insurance policy while retaining security responsibilities.
Accept	Formally retain the risk within an approved tolerance.	Document a low-impact exception with an owner and expiry.

Risk transfer does not remove accountability or prevent harm. Acceptance should be an informed, authorized decision, not the result of an untracked omission.

Qualitative and quantitative assessment

Qualitative approaches use categories such as low, medium, and high. Quantitative approaches use numerical estimates. Either can be useful if the method, assumptions, and decision thresholds are understood. A precise-looking number is not automatically a precise estimate.

Example workflow

For a vulnerable server, establish which data and services it supports, whether it is exposed, the plausible threat path, business impact, and current safeguards. Prioritize remediation according to impact, exploitability, exposure, and service dependencies. Record the decision and validate the change after remediation.

Common mistakes

- Treating a risk register as a one-time inventory rather than a living record.
- Ranking solely by technical severity while ignoring reachability and business context.
- Recording a treatment without an owner, due date, or verification step.
- Assuming a vendor or insurer takes over all responsibility.

Revision points

- Assess risk in context and state assumptions.
- Choose and document a treatment, owner, and review point.
- Reassess after material changes to assets, exposure, controls, or threats.

Security Controls

What a control does

A security control is a safeguard or process used to prevent, detect, or respond to unwanted events and reduce risk. Controls can be grouped by purpose or by how they are implemented.

Grouping	Types	Examples
By function	Preventive, detective, corrective	Access restrictions; monitoring alerts; restoring from a known-good backup.
By implementation	Technical, administrative, physical	MFA; an approved access policy; a locked server room.

A control's presence does not prove it works. Define its intended outcome, assign ownership, and check operation and coverage.

Layered protection

Layering controls reduces reliance on one safeguard. For example, MFA can reduce account takeover risk, least-privilege authorization can limit what a compromised account can do, and logging can help detect suspicious activity. Each control has failure modes; together they can limit the chance or impact of harm.

Practical example

To protect an administrative account: require strong authentication, grant elevated permissions only when needed, log privileged actions, alert on unusual use, and maintain a tested recovery path. Review access when job duties change.

Common mistakes

- Assuming a policy alone enforces a control.
- Treating a tool purchase as evidence that risk is reduced.
- Applying a control without considering usability, exceptions, and bypass paths.
- Relying on one preventive measure without detection or recovery capability.

Revision points

- State the risk a control addresses and the result it should produce.
- Distinguish prevention, detection, and correction.
- Validate that the control is configured, operating, and reviewed.

Incident Response

Purpose

Incident response provides an organized way to handle suspected or confirmed security events. A consistent workflow helps limit harm, coordinate decisions, preserve useful evidence, restore services, and improve future readiness.

A practical workflow

Stage	Main activity	Example question
Prepare	Define roles, contacts, tools, escalation, and decision authority.	Who can isolate a production endpoint?
Detect and analyze	Validate signals, establish scope, and assess severity.	Is this login pattern expected, and which accounts are involved?
Contain	Limit ongoing impact while preserving critical operations.	Can the affected host be isolated safely?
Eradicate	Remove the cause and unauthorized access.	Has the vulnerable service been fixed and persistence removed?
Recover	Restore services and monitor for recurrence.	Are systems clean, stable, and approved to return?
Learn	Record findings and improve controls and procedures.	Which detection or response step should change?

Organizations may name or combine these stages differently. Follow the approved incident plan and applicable reporting requirements.

Evidence and communication

Keep a clear timeline, record actions and decision-makers, preserve relevant logs and artifacts according to policy, and restrict access to sensitive incident material. Coordinate communications through designated roles. Avoid changing affected systems before evidence needs and containment trade-offs have been considered.

Example

A SIEM alert shows a privileged account used from an unusual location. An analyst validates the event with identity and endpoint records, escalates under policy, and works with the system owner to contain access. The team determines scope, removes unauthorized access, restores normal operation, and documents follow-up actions.

Common mistakes

- Confusing an alert with a confirmed incident.
- Delaying escalation while waiting for certainty.
- Making undocumented changes that complicate investigation or recovery.

- Restoring systems before confirming the cause has been addressed.
- Closing the incident without recording lessons and owners for follow-up work.

Revision points

- Prepare before an incident: roles, authority, contacts, and evidence handling.
- Validate and scope before selecting containment actions.
- Track a timeline, communicate through assigned channels, and verify recovery.
- Use lessons learned to improve readiness and controls.

Sources and access notes

Google Cybersecurity Certificate playlist: playlist. Google published curriculum: course page.

The public playlist feed exposed module video titles but not lesson transcripts. These notes summarize fundamentals within the published course curriculum and do not claim a video-by-video transcript.